

SentinelX External Exposure Intelligence Report

Passive Reconnaissance Assessment — Confidential

getmarlee.com

Generated: 2026-03-06 07:25 UTC

Assessment Metadata

Assessment Type
External Passive Reconnaissance
Target Scope
External passive reconnaissance of getmarlee.com and its publicly observable subdomain infrastructure
Timestamp
2026-03-06T07:25:39.492065+00:00
Scanner Version
SentinelX v1.2.0
Analyst
SentinelX Automated Engine
Methodology
Passive external reconnaissance only. All data collected from publicly accessible sources including: HTTPS certificate inspection, HTTP response header analysis, DNS record enumeration, certificate transparency log queries (crt.sh), favicon hash fingerprinting, and TCP port probing of well-known service ports. No authentication, exploitation, or active intrusive testing was performed at any stage.

Exposure Score

Composite 1–10 Risk Metric

4

Medium

Medium Exposure

Moderate external exposure. Several risk indicators were identified. Structured remediation within 60 days is recommended.

4 / 10

■ Exposure Score Methodology

The Exposure Score is a 1–10 composite metric representing the organisation's external attack surface as observed from a fully passive reconnaissance perspective. Higher scores indicate broader, more exploitable exposure.

+2

Expired TLS Certificate

An expired certificate disables transport security warnings and signals operational neglect.

+2

High-Risk Pattern Subdomains Detected

Subdomains matching patterns such as 'dev', 'admin', 'staging' indicate pre-production or privileged surfaces.

+2

Sensitive Ports Publicly Reachable

Ports such as 22 (SSH), 3306 (MySQL), 3389 (RDP) present direct attack vectors for credential attacks.

+1

Missing HSTS Header

Absence of Strict-Transport-Security enables protocol downgrade and session interception.

+1

Missing Content-Security-Policy

Absence of CSP leaves the application unprotected against cross-site scripting injection.

+1

Missing X-Frame-Options

Without frame protection, authenticated interfaces are vulnerable to clickjacking.

+1

Large Subdomain Attack Surface (>5 hosts)

A broad subdomain footprint increases enumeration potential and the probability of a misconfigured host.

Low (1–3)

Minimal observable exposure. Basic hygiene controls appear to be in place.

Medium (4–7)

Moderate exposure. Several risk indicators present; structured remediation recommended within 60 days.

High (8–10)

Significant external exposure. Immediate prioritised remediation required.

Attack Surface Overview

1

Subdomains Discovered

1

Sensitive Open Ports

1

Critical Headers Missing

0

High-Risk Subdomains

Valid

TLS Certificate Status

6

Technology Indicators

Ember.js HubSpot CMS Next.js (React SSR) React Server: cloudflare X-Powered-By: Next.js, Payload

High

1

1

Medium

1

1

Low

2

2

Executive Summary

High Risk

Passive external reconnaissance of getmarlee.com identified a medium exposure posture across 1 resolvable subdomain(s). The assessment surfaced 1 high-severity and 1 medium-severity indicators warranting structured remediation attention.

Primary Risk #1

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploitation, and lateral movement.

Primary Risk #2

HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level interception.



Prioritise remediation of High-severity findings within the next 30 days. Schedule a follow-up passive assessment in 90 days to validate posture improvement.

This assessment relied exclusively on passive, publicly observable signals. No intrusive testing, exploitation, or active probing was performed at any stage.

Security Findings

1. Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploi

A05:2021 – Security Misconfiguration **High**

Technical Description

Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploitation, and lateral movement.

Security Impact

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

Business Impact

DataExposure Risk

Dependent on service exposed — evaluate data access scope.

Credential Compromise Risk

Possible if authentication interfaces or credentials are reachable.

Infrastructure Enumeration Risk

External adversaries can map service topology from observable signals.

Compliance Risk

May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.

Reputation Risk

Publicly observable misconfigurations erode technical credibility with enterprise buyers.

■ Threat Scenario

An adversary performing targeted reconnaissance identifies this condition and incorporates it into a structured attack plan, using it as an initial foothold for credential theft, data exfiltration, or further lateral movement.

■ Remediation Recommendation

Review this finding with your infrastructure team and apply targeted hardening controls.

■ Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

2. HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level intercep

A02:2021 – Cryptographic Failures **Medium**

Technical Description

HSTS header absent — browsers may permit unencrypted HTTP connections, exposing session tokens to network-level interception.

Security Impact

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

Business Impact

DataExposure Risk

Dependent on service exposed — evaluate data access scope.

Credential Compromise Risk

Possible if authentication interfaces or credentials are reachable.

Infrastructure Enumeration Risk

External adversaries can map service topology from observable signals.

Compliance Risk

May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.

Reputation Risk

Publicly observable misconfigurations erode technical credibility with enterprise buyers.

Threat Scenario

An adversary positioned on the same network segment as a target user (hotel Wi-Fi, conference network) initiates an SSL Strip attack using a tool such as sslstrip. Because HSTS is absent, the victim's browser accepts an unencrypted HTTP connection. The attacker captures the session cookie from the HTTP request and replays it against the application's authenticated API, achieving full account access.

Remediation Recommendation

In Cloudflare Dashboard → SSL/TLS → Edge Certificates → Enable HSTS with max-age=31536000 and includeSubDomains. General guidance: Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains; preload' to all HTTPS responses. Submit the domain to the HSTS preload list at hstspreload.org once confirmed stable.

Technology-Specific Implementation

In Cloudflare Dashboard → SSL/TLS → Edge Certificates → Enable HSTS with max-age=31536000 and includeSubDomains.

3. Valid TLS endpoint reachable. Certificate chain and expiry details collected.

A02:2021 – Cryptographic Failures **Low**

Technical Description

Valid TLS endpoint reachable. Certificate chain and expiry details collected.

Security Impact

This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

Business Impact
DataExposure Risk
Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk
Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk
External adversaries can map service topology from observable signals.
Compliance Risk
May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk
Publicly observable misconfigurations erode technical credibility with enterprise buyers.

■ Threat Scenario

An adversary performing targeted reconnaissance identifies this condition and incorporates it into a structured attack plan, using it as an initial foothold for credential theft, data exfiltration, or further lateral movement.

■ Remediation Recommendation

Review this finding with your infrastructure team and apply targeted hardening controls.

■ Technology-Specific Implementation

Apply remediation according to your web server and framework documentation.

4. Technology stack fingerprinted (6 indicators). Public exposure of framework and version information may inform targeted

A06:2021 – Vulnerable and Outdated Components Low

Technical Description
Technology stack fingerprinted (6 indicators). Public exposure of framework and version information may inform targeted research.

Security Impact
This condition represents a validated passive indicator of external exposure. The specific impact depends on how an adversary leverages this signal.

Business Impact
DataExposure Risk
Dependent on service exposed — evaluate data access scope.
Credential Compromise Risk
Possible if authentication interfaces or credentials are reachable.
Infrastructure Enumeration Risk
External adversaries can map service topology from observable signals.
Compliance Risk
May constitute a control gap under SOC 2, PCI-DSS, or GDPR depending on data classification.
Reputation Risk

Publicly observable misconfigurations erode technical credibility with enterprise buyers.

■ Threat Scenario

The detected framework version is cross-referenced with CVE databases, revealing a known Remote Code Execution vulnerability. The attacker downloads a public proof-of-concept and validates it against the target without triggering any security alerts. A reverse shell is established, granting operating system level access to the application server and all data it can reach.

■ Remediation Recommendation

Suppress version-revealing response headers (Server, X-Powered-By, X-Generator). In Nginx: server_tokens off; In Apache: ServerTokens Prod; ServerSignature Off. Ensure all detected frameworks are on current stable versions.

■ Technology-Specific Implementation

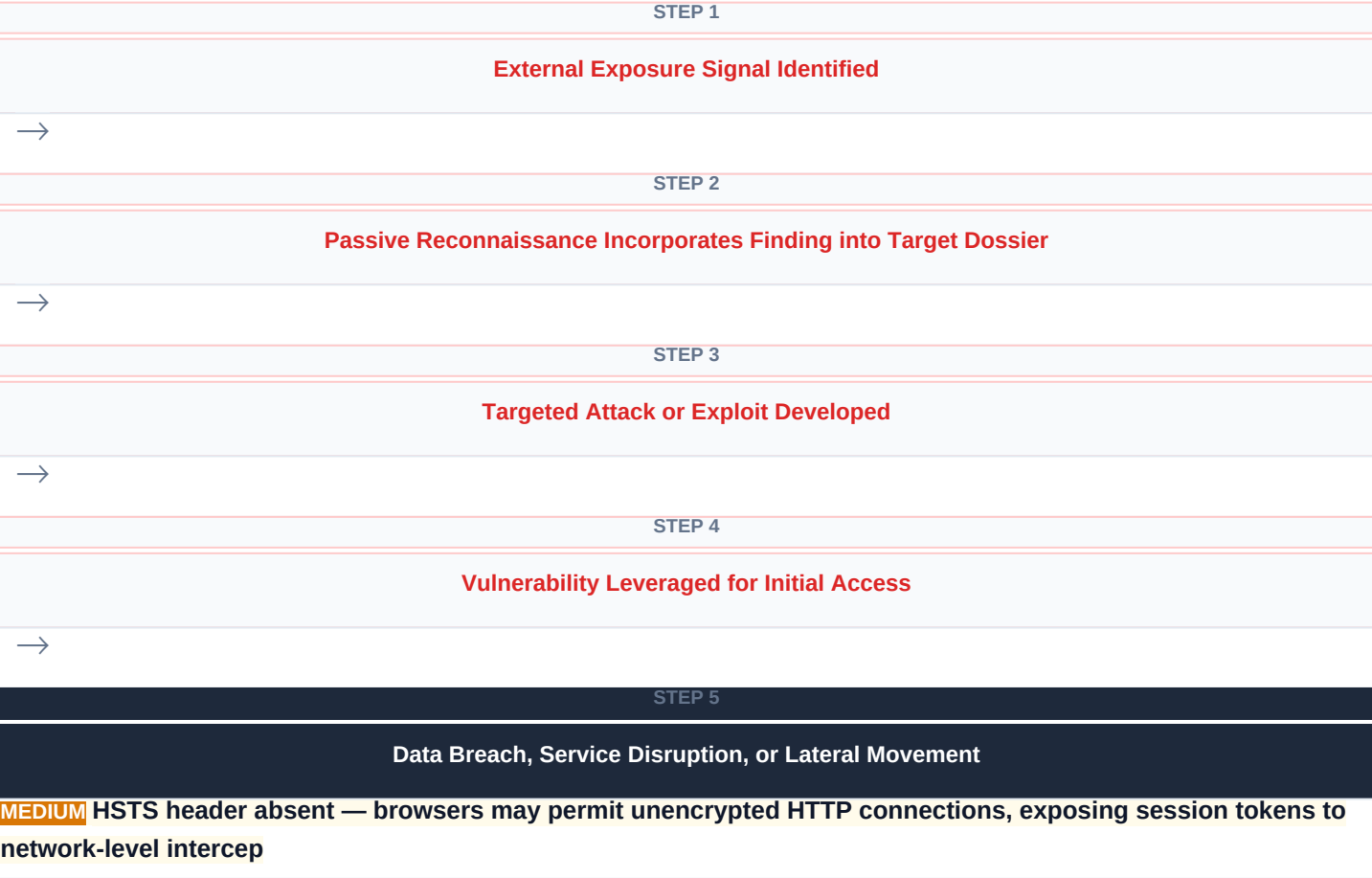
Apply remediation according to your web server and framework documentation.

Potential Attack Paths

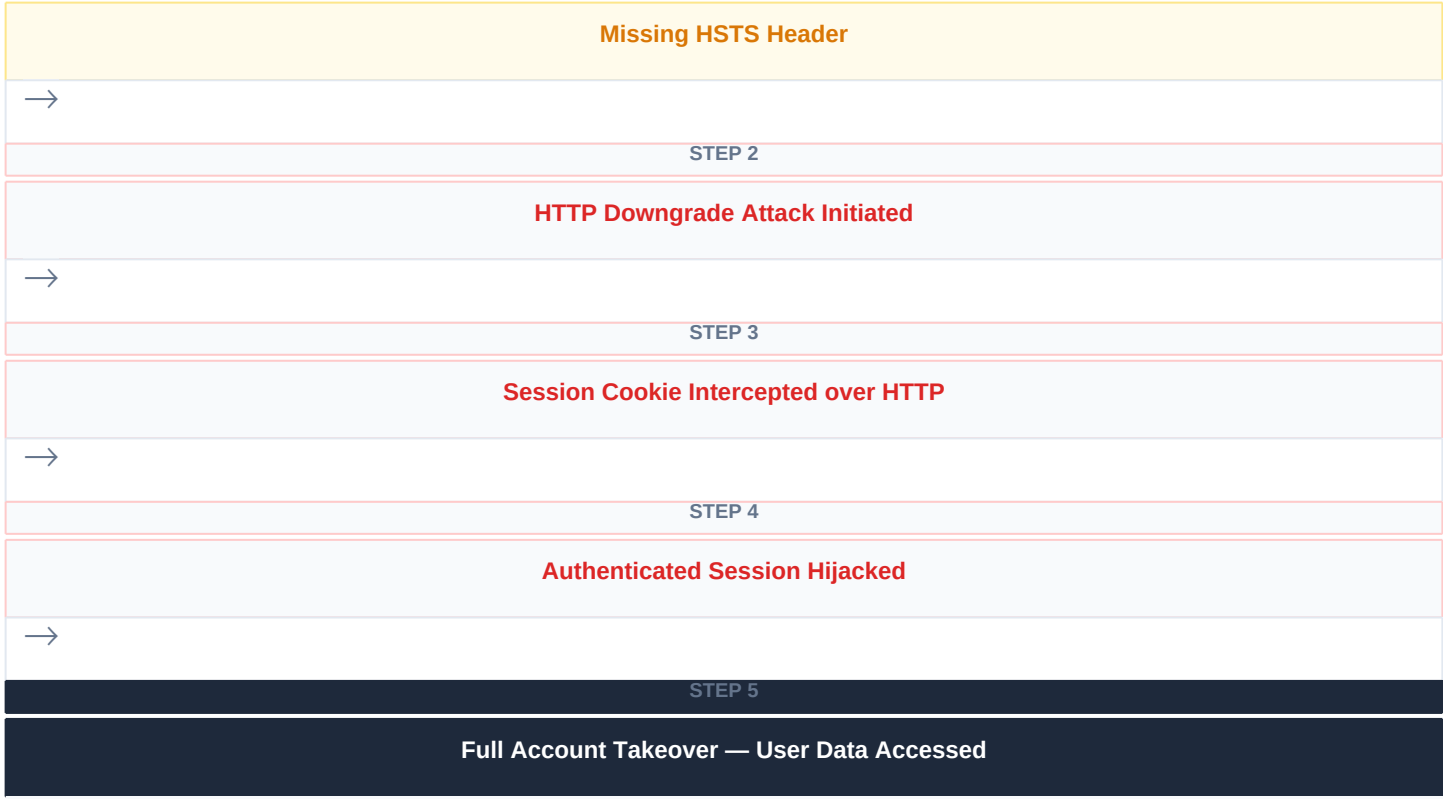
■ Potential Attack Paths

How findings chain into business impact

HIGH Sensitive service ports publicly reachable (21) — direct attack surface for credential brute-force, vulnerability exploi



STEP 1



Technical Appendix

A.1 — TLS Certificate Details

Attribute	Value
Reachable	Yes
Subject (CN)	getmarlee.com
Issuer (CA)	E7
Valid From	Jan 20 18:15:12 2026 GMT
Valid To	Apr 20 18:15:11 2026 GMT
Days Remaining	45
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384

Certificate Expired	No
---------------------	----

A.2 — Security Header Analysis

Header	Present	Value
Strict-Transport-Security	No	—
Content-Security-Policy	Yes	frame-ancestors 'self';
X-Frame-Options	Yes	SAMEORIGIN
X-Content-Type-Options	No	—
Referrer-Policy	No	—
Permissions-Policy	No	—
Cross-Origin-Opener-Policy	No	—
Cross-Origin-Resource-Policy	No	—

A.3 — Open Port Enumeration

Port	Service	Exposure Classification
21	FTP	High Exposure
80	HTTP	Standard Web
443	HTTPS	Standard Web
8080	HTTP (alt)	Standard Web

8443	HTTPS (alt)	Standard Web
------	-------------	--------------

A.4 — Subdomain Enumeration

1 host(s) resolved

getmarlee.com

A.5 — DNS Reconnaissance

A IPv4 Address Records 172.66.43.95 172.66.40.161

MX Mail Exchange Records aspmx.l.google.com alt3.aspmx.l.google.com alt4.aspmx.l.google.com alt1.aspmx.l.google.com alt2.aspmx.l.google.com

TXT Text Records

#	Record Value
1	Validity-Domain-Verification=VRnxTI1Hv5mDtv4rgQNvXXzhG4I=
2	atlassian-domain-verification=Y3lhgyirCPMrPdX1iWztCw8c6K7
3	facebook-domain-verification=1d0km2xsgdsq0005i02eqc09leot
4	google-site-verification=-mSHSFaZ0P6YPpHgLQ_SagNsCjDGqf80
5	google-site-verification=8EsnfktmI3zKlnFtkUETwr53pFcMXtWN
6	google-site-verification=L4x77J479GcbMoTuQJEfLfyhX70AXTza
7	google-site-verification=TB4-rmUbK34KzwZTAn4y9ByExvcu1mqf
8	google-site-verification=pYisS53fayofk8yjbPvxClV9aao7GwzK
9	klaviyo-site-verification=YwLY8c

10	pininterest-site-verification=8c4b9f45ca4fab54a94554te38bd
11	v=spf1 include:_spf.mx.cloudflare.net include:_spf.google.com include:_spf.salesforce.com include:amazonses.com ~all

SPF Record

v=spf1 include:_spf.mx.cloudflare.net include:_spf.google.com include:_spf.salesforce.com
include:amazonses.com ~all

DMARC Record

Not found — without DMARC, phishing emails spoofing this domain may not be rejected.

A.6 — Certificate Transparency (crt.sh)

1 host(s) via CT logs

The following subdomains were discovered passively via certificate transparency log queries (crt.sh). CT logs record all issued certificates, revealing historical and current subdomain infrastructure.

getmarlee.com

Disclaimer & Limitations

This report was generated by SentinelX v1.2.0 using exclusively passive, non-intrusive reconnaissance techniques. All data was collected from publicly observable sources including certificate transparency logs, public DNS records, HTTP response headers, and TCP port availability. No exploitation, credential testing, or authenticated access was performed. Findings represent risk indicators observable from the public internet and do not constitute a complete security assessment. A full penetration test by qualified security professionals is recommended to validate and prioritise these findings.